



ISP-001 — Information Security Policy

Overleaf Publishers Ltd · Co. No. 15735226 · VAT No. 479581629 · Version 1.0 · July 2026 · chainsawcourses.com

1. PURPOSE AND POLICY STATEMENT

Overleaf Publishers Ltd is committed to protecting the confidentiality, integrity, and availability of all information assets — whether relating to learners, business operations, course content, or third-party providers. This policy establishes the framework for managing information security risks across the organisation, and applies to all personnel, contractors, systems, and processes. Document reference: ISP-001.

The organisation recognises that information security is a business-critical function: learner personal data is processed at scale; device-bonded activation codes represent direct commercial value; and the integrity of safety-critical course content has a direct impact on learner welfare.

2. INFORMATION SECURITY OBJECTIVES

- Protect learner personal data in compliance with UK GDPR and the Data Protection Act 2018.
- Maintain confidentiality of activation codes and commercial information.
- Ensure platform integrity — prevention of unauthorised modification of course content or assessment records.
- Maintain platform availability — learner access is not disrupted by preventable security failures.
- Detect, respond to, and recover from information security incidents within defined timescales.
- Ensure all personnel and contractors understand and fulfil their information security obligations.

3. INFORMATION ASSET CLASSIFICATION

CLASSIFICATION — DESCRIPTION	EXAMPLES
Confidential — sensitive; restricted to named individuals; serious harm if disclosed	Learner PII; activation codes; financial records; admin credentials; data breach records
Internal — for use within the organisation; not for public release	Internal procedures; audit reports; supplier contracts; management review minutes
Public — approved for external release; no restriction	Marketing materials; published policies; course syllabus; platform FAQs

All information assets are treated as Confidential by default unless explicitly classified otherwise. The Asset Register (maintained by the Director) lists all key information assets, their classification, owner, location, and applicable controls.

4. ROLES AND RESPONSIBILITIES

- Director: overall accountability for information security; approves security policy and procedures; leads incident response.
- All personnel and contractors: responsible for complying with this policy and associated procedures; reporting suspected security incidents without delay.
- Platform systems: automated controls (device locking, session management, rate limiting, encrypted transmission) operated and monitored by the Director.

5. TECHNICAL SECURITY CONTROLS

CONTROL	IMPLEMENTATION
Data transmission encryption	All data transmitted over HTTPS/TLS 1.2+ enforced across all platform endpoints
Database encryption	PostgreSQL database encrypted at rest; hosted on Replit infrastructure with encryption by default
Authentication	Activation code + device UUID + user ID triple validation on all authenticated API calls
Password / secret management	All secrets stored in environment variables (Replit Secrets); never hardcoded; rotated on suspicion of compromise
Access control	Role-based access: learners access only their own records; admin access requires separate token with 24h TTL
Session management	Admin sessions expire after 24 hours; learner sessions tied to device UUID stored in localStorage
Video content protection	Vimeo domain-restricted embeds; dynamic learner watermark repositions every 60 seconds
Anti-sharing	Activation codes bonded to first device at redemption; administrator can reset device bond on verified request only
Input validation	All API inputs validated with Zod schemas; parameterised queries prevent SQL injection
Rate limiting	API rate limiting applied to all authentication endpoints
Backup and recovery	Database backups managed per Business Continuity and Disaster Recovery Plan

6. PHYSICAL SECURITY

As a remote-first organisation, physical security controls focus on: securing personal devices used for work (screensaver lock "d5 minutes; full-disk encryption); physical access to any premises where business data is processed; and secure disposal of physical media containing business data (cross-shredding for paper; cryptographic erasure or physical destruction for digital media).

7. HUMAN RESOURCES SECURITY

- All staff and contractors receive an information security briefing on engagement.
- Contractors with access to personal data or systems sign a confidentiality and data processing agreement.
- Access rights are provisioned on a least-privilege, need-to-know basis and revoked immediately on termination of engagement.
- Personnel are required to report suspected security incidents without delay — no detriment for good-faith reports.

8. THIRD-PARTY AND CLOUD SERVICE SECURITY

The security of third-party providers (Replit, Vimeo, payment processors) is reviewed annually under the Supplier and Contractor Evaluation Policy. All third parties processing personal data are subject to a data

processing agreement (DPA). Cloud services used are: Replit (hosting, UK/EU data residency); Vimeo (video CDN); and payment processors subject to PCI-DSS compliance. Security-relevant provider notifications (breach disclosures, vulnerability advisories) are assessed by the Director within 2 working days of receipt.

9. SECURITY INCIDENT MANAGEMENT

All suspected or confirmed information security incidents are managed under the Data Breach and Incident Response Procedure. The Director is the primary incident owner. All personnel and contractors are required to report suspected incidents immediately upon detection.

10. SECURITY REVIEW AND IMPROVEMENT

Information security performance is reviewed at each management review. The Asset Register and technical controls are reviewed annually. Security incident trends are analysed for systemic weaknesses. External penetration testing or security assessment is considered annually and commissioned where risk assessment indicates necessity.

11. POLICY REVIEW

This policy is reviewed annually and following any significant security incident, regulatory change, or material change in the technical environment. Controlled under reference ISP-001.

For queries: info@chainsawcourses.com · Overleaf Publishers Ltd · Reg. No. 15735226 · VAT 479581629